

Halonyx: A Secure Decentralized Messaging Application

Literature Review

Aligned with Software Design Document v1.0

Team: Abhiram P | Geo Jose | Anirudh | Antony S Kannampuzha **Department:** Computer Science and Engineering **Institution:** Sree Narayana Gurukulam College of Engineering (SNGCE), Kerala **Year:** 2026

1. Introduction

The rapid proliferation of digital communication platforms has made the security and privacy of messaging systems a critical concern in both academic and applied computer science. Halonyx is a secure messaging web application that leverages the Signal Protocol — comprising the Extended Triple Diffie-Hellman (X3DH) key exchange and the Double Ratchet Algorithm — alongside AES-256-GCM symmetric encryption, USID-based anonymous identity management, JWT-authenticated WebSocket communication, and a three-tier Node.js/SQLite architecture.

This literature review surveys fifteen foundational and contemporary research works that collectively inform the design decisions of the Halonyx system. The review is organized thematically across five areas: (1) the Signal Protocol and its formal security analysis, (2) the Double Ratchet Algorithm, (3) authenticated encryption and AES-GCM, (4) privacy-preserving identity management, and (5) secure real-time communication architectures.

2. Review of Literature

2.1 The Signal Protocol: Design, Adoption, and Security Analysis

[1] Marlinspike, M. & Perrin, T. (2016) — "The X3DH Key Agreement Protocol" *Signal Specification*, 2016

The foundational specification for X3DH describes how two parties can establish a shared secret key through asynchronous authenticated key exchange without prior interaction. The

protocol performs four Diffie-Hellman operations — combining identity keys, signed pre-keys, and ephemeral one-time pre-keys — whose outputs are passed through HKDF to derive an initial shared secret. X3DH provides forward secrecy and cryptographic deniability, meaning no cryptographic proof can be produced that a given party sent a particular message. Halonyx directly implements this four-DH structure, and the semi-trusted server model — where the server stores pre-key bundles but never learns message content — mirrors Halonyx's Node.js backend design.

[2] Perrin, T. & Marlinspike, M. (2016) — "The Double Ratchet Algorithm" *Signal Specification*, 2016

This specification describes the core ratcheting mechanism used after X3DH session establishment. The Double Ratchet maintains three KDF chains — root, sending, and receiving — and combines a symmetric-key ratchet with a DH ratchet, providing per-message key derivation for forward secrecy and post-compromise security. Earlier session keys cannot be computed from later ones. Halonyx implements this mechanism in its Double Ratchet module, and the specification's treatment of out-of-order message handling directly informs the session state lifecycle management in the system.

[3] Cohn-Gordon, K., Cremers, C., Dowling, B., Garratt, L., & Stebila, D. (2020) — "A Formal Security Analysis of the Signal Messaging Protocol" *Journal of Cryptology*, 33(4), 1914–1983

This landmark paper presents the first rigorous formal security analysis of Signal's combined X3DH and Double Ratchet protocols, modelling the key update structure as a multi-stage authenticated key exchange. The authors prove standard security properties including forward secrecy and post-compromise security and find no major design flaws, establishing Signal as a cryptographically sound foundation. This finding directly validates Halonyx's choice of Signal Protocol as its encryption backbone. The paper further notes Signal's deployment across over one billion users via WhatsApp, Wire, and Facebook Messenger, underscoring its industrial maturity.

[4] Zhang, Z. et al. (2024) — "Formal Analysis of Signal Protocol Based on Logic of Events Theory" *Scientific Reports, Nature*, 14, 20565

This study proposes a formal analysis method using Logic of Events Theory (LoET) to analyze Signal's composed X3DH and Double Ratchet structure. The analysis reveals that Signal does not fully satisfy a strong authentication property during the X3DH phase — specifically related to identity misbinding — though this does not constitute a practically exploitable flaw. For Halonyx, this finding reinforces the importance of the hashed USID scheme as an additional

identity-binding layer, ensuring that contacts are added by verified USID values rather than through unguarded public-key lookup.

[5] Brendel, J. et al. (2022) — "An Efficient and Generic Construction for Signal's Handshake (X3DH): Post-Quantum, State Leakage Secure, and Deniable" *NIST 4th PQC Standardization Conference, 2022*

This paper presents a post-quantum secure replacement for X3DH that preserves deniability, using ring signatures to strengthen authentication guarantees and demonstrating that CRYSTALS-Dilithium and SPHINCS+ can be substituted without sacrificing existing security properties. This work is directly relevant to Halonyx's planned future enhancement for post-quantum cryptography, representing the state-of-the-art pathway Halonyx can adopt when NIST-standardized quantum-resistant algorithms are finalized.

2.2 The Double Ratchet Algorithm: Security Notions and Extended Analysis

[6] Alwen, J., Coretti, S., & Dodis, Y. (2019) — "The Double Ratchet: Security Notions, Proofs, and Modularization for the Signal Protocol" *EUROCRYPT 2019*

This work presents the first modular, game-based security analysis of the Double Ratchet, formalizing its "immediate decryption" property — the ability to decrypt messages in any order without delay. The authors demonstrate that per-message key derivation provides forward secrecy, while the DH ratchet provides break-in recovery after a key compromise. Halonyx's session state model (CREATING → INITIALIZED → ESTABLISHED → CLOSED) reflects the lifecycle implied by this formalization, particularly the distinction between the X3DH initialization phase and the ongoing ratcheting phase.

[7] Bienstock, A. et al. (2022) — "A More Complete Analysis of the Signal Double Ratchet Algorithm" *CRYPTO 2022, LNCS 13508, pp. 574–603*

This paper develops a new Universally Composable (UC) definition for the Double Ratchet, identifying six modified DR variants that are insecure under the new definition despite being secure under earlier models. It formally demonstrates that the standard DR protocol provably resists CCA-style attacks immediately after a key compromise. For Halonyx, this confirms that the threat mitigation of never persisting session keys to disk is cryptographically sound, and it informs the design choice of per-message unique nonces in AES-256-GCM encryption.

2.3 Authenticated Encryption: AES-GCM and HKDF

[8] McGrew, D. & Viega, J. (2004) — "The Galois/Counter Mode of Operation (GCM)" *NIST Submission / IEEE, 2004*

This foundational paper introduces GCM as an authenticated encryption with associated data (AEAD) mode, combining the Counter (CTR) mode for confidentiality with Galois field multiplication for authentication, producing both ciphertext and an authentication tag in a single pass. NIST subsequently standardized AES-GCM in SP 800-38D. Halonyx adopts AES-256-GCM with a 256-bit key and 96-bit nonce matching standard parameters. The authentication tag ensures that tampering with ciphertext is detected before decryption, directly addressing the tamper-proof messaging objective of the system.

[9] Bellare, M. & Tackmann, B. (2016) — "The Multi-User Security of Authenticated Encryption: AES-GCM in TLS 1.3" *IACR ePrint 2016/564*

This paper analyzes AES-GCM under a multi-user security model, demonstrating that without nonce randomization, the security bound degrades as the number of users grows. For Halonyx, which supports multiple simultaneous sessions, this validates the use of per-message unique nonces derived from the Double Ratchet, since fresh key material is produced per message rather than relying on a static key with incrementing nonces — a critical consideration for a multi-user messaging platform.

[10] McGrew, D. & Igoe, K. (2015) — "AES-GCM Authenticated Encryption in the Secure Real-time Transport Protocol (SRTP)" *RFC 7714, IETF, 2015*

RFC 7714 defines the use of AES-GCM in real-time communication protocols, specifying that authentication tags must be 128 bits and that key and nonce lengths are fixed per session. This standard is relevant to Halonyx's WebSocket-based real-time message delivery, where each message must maintain authenticated integrity against in-transit tampering. The RFC confirms that Halonyx's 96-bit nonce and 128-bit tag configuration is consistent with IETF-standardized best practice.

2.4 Privacy-Preserving Identity Management

[11] Kröger, J.L. & Lindemann, J. (2025) — "Privacy-Preserving Authentication: Theory vs. Practice" *arXiv:2501.07209*

This comprehensive survey examines the gap between academic advances in anonymous credentials and their real-world deployment, describing how anonymous credential systems allow users to prove attributes without revealing underlying identifiers. The survey notes that despite decades of research, these schemes still lack widespread adoption. Halonyx's USID

design takes a pragmatic approach: rather than implementing full anonymous credential cryptography, it generates a 256-bit random identifier and stores only its SHA-256 hash, achieving pseudonymity and unlinkability without the computational overhead of zero-knowledge proofs.

[12] Garcia-Carrillo, D. et al. (2017) — "Holistic Privacy-Preserving Identity Management System for the Internet of Things" *Security and Communication Networks*, Hindawi

This paper proposes an identity management system combining classic IdM with anonymous credential approaches, achieving pseudonymity, minimal disclosure, and unlinkability. It introduces hashed identifiers as a binding mechanism across distributed database components where a hash links records across subsystems without exposing plaintext identity. This architecture closely mirrors Halonyx's dual-database design, where *hashed_usid* links *identity.db* and *app.db*, ensuring operational activity cannot be trivially correlated with personal identity information.

[13] Acien, A. et al. (2021) — "Privacy-Preserving Sensor-Based Continuous Authentication and User Profiling: A Review" *MDPI Sensors*, 21(1), 92

This survey covers privacy-preserving authentication techniques, including the use of SHA-2/SHA-3 hash functions for creating pseudo-anonymous user identifiers. It establishes that hash functions are effective for identity binding without disclosure — allowing a system to verify that a presented identifier matches a stored hash without ever storing or transmitting the plaintext. This principle is central to the Halonyx USID lifecycle, where the server stores only SHA-256(USID) and never the raw USID in persistent storage.

[14] Rasheed, S. et al. — "Deniable Identity-Based Matchmaking Encryption for Anonymous Messaging" *Semantic Scholar*

This paper introduces a framework for anonymous messaging that provides both plausible deniability and mutual authentication simultaneously, formalizing the threat model under coercion and constructing a deniable identity-based matchmaking encryption scheme with security proved in the random oracle model. Halonyx explicitly lists deniability as a security property, claiming that no cryptographic proof can establish that a message was sent by a particular party. This paper situates that design goal within a formal framework and reveals future directions for strengthening Halonyx's deniability model against coercive adversaries.

2.5 Secure Real-Time Communication Architectures

[15] Bawake, H. et al. (2023) — "A Secure Messaging Application with Unbreakable End-to-End Encryption" *International Journal of Research and Analytical Studies (IJRASET)*, 2023

This applied research paper describes the implementation of a Node.js/WebSocket-based secure chat application using the Signal Protocol for end-to-end encryption alongside REST APIs for authentication and contact management. The authors confirm that the WebSocket library in Node.js is well-suited for persistent bi-directional secure communication and that JWT effectively authenticates both REST and WebSocket interactions. This architecture is structurally identical to Halonyx's design, where REST endpoints handle registration and contact management while WebSocket handles real-time encrypted delivery. The paper also identifies group messaging and guaranteed delivery as key future enhancements, aligning with Halonyx's development roadmap.

3. Thematic Synthesis

The fifteen works surveyed collectively establish the theoretical and empirical foundations for each major component of the Halonyx system. The Signal Protocol literature (Papers 1–5) confirms that the four-DH X3DH structure and pre-key bundle architecture are both functionally correct and cryptographically sound, while also identifying a clear post-quantum upgrade path. The Double Ratchet analyses (Papers 6–7) formally justify the per-message key derivation scheme and the design decision never to persist session keys. The AES-GCM literature (Papers 8–10) validates the selected cryptographic parameters against NIST and IETF standards. The identity management works (Papers 11–14) ground the dual-database hashed USID architecture in established pseudonymity research and formally frame Halonyx's deniability claim. Finally, the applied implementation study (Paper 15) reduces architectural risk by demonstrating production viability of the Node.js + WebSocket + REST + JWT stack for Signal Protocol-based messaging.

Theme	Papers	Key Validation
Signal Protocol	[1]–[5]	X3DH four-DH structure and pre-key architecture are cryptographically sound; post-quantum upgrade path identified
Double Ratchet	[6]–[7]	Per-message key derivation achieves forward secrecy; non-persistence of session keys formally justified
AES-GCM Encryption	[8]–[10]	AES-256-GCM with 96-bit nonce and per-message fresh keys is IETF-standardized and multi-user secure
Privacy Identity	[11]–[14]	hashed_usid dual-DB design mirrors best practices; SHA-256 pseudonymity and deniability formally grounded

Architecture [15] Node.js + WebSocket + REST + JWT stack is production-validated for Signal Protocol-based E2EE applications

4. References

- [1] Marlinspike, M. & Perrin, T. (2016). *The X3DH Key Agreement Protocol*. Signal Specification. Retrieved from <https://signal.org/docs/specifications/x3dh/>
- [2] Perrin, T. & Marlinspike, M. (2016). *The Double Ratchet Algorithm*. Signal Specification. Retrieved from <https://signal.org/docs/specifications/doubleratchet/>
- [3] Cohn-Gordon, K., Cremers, C., Dowling, B., Garratt, L., & Stebila, D. (2020). A formal security analysis of the Signal messaging protocol. *Journal of Cryptology*, 33(4), 1914–1983. <https://doi.org/10.1007/s00145-020-09360-1>
- [4] Zhang, Z. et al. (2024). Formal analysis of Signal protocol based on logic of events theory. *Scientific Reports*, 14, 20565. <https://doi.org/10.1038/s41598-024-71666-y>
- [5] Brendel, J. et al. (2022). An efficient and generic construction for Signal's handshake (X3DH): Post-quantum, state leakage secure, and deniable. *NIST 4th PQC Standardization Conference*.
- [6] Alwen, J., Coretti, S., & Dodis, Y. (2019). The Double Ratchet: Security notions, proofs, and modularization for the Signal Protocol. In *Advances in Cryptology — EUROCRYPT 2019*, LNCS 11477. Springer.
- [7] Bienstock, A. et al. (2022). A more complete analysis of the Signal Double Ratchet Algorithm. In *Advances in Cryptology — CRYPTO 2022*, LNCS 13508, pp. 574–603. Springer.
- [8] McGrew, D. & Viega, J. (2004). *The Galois/Counter Mode of Operation (GCM)*. NIST Submission. Cisco Systems.
- [9] Bellare, M. & Tackmann, B. (2016). The multi-user security of authenticated encryption: AES-GCM in TLS 1.3. *IACR Cryptology ePrint Archive*, Report 2016/564. Retrieved from <https://eprint.iacr.org/2016/564.pdf>
- [10] McGrew, D. & Igoe, K. (2015). *AES-GCM authenticated encryption in the Secure Real-time Transport Protocol (SRTP)*. RFC 7714. Internet Engineering Task Force. <https://datatracker.ietf.org/doc/rfc7714/>
- [11] Kröger, J.L. & Lindemann, J. (2025). Privacy-preserving authentication: Theory vs. practice. *arXiv preprint arXiv:2501.07209*. Retrieved from <https://arxiv.org/html/2501.07209v1>

[12] Garcia-Carrillo, D. et al. (2017). Holistic privacy-preserving identity management system for the Internet of Things. *Security and Communication Networks*. Hindawi Publishing.

[13] Acien, A. et al. (2021). Privacy-preserving sensor-based continuous authentication and user profiling: A review. *Sensors*, 21(1), 92. <https://doi.org/10.3390/s21010092>

[14] Rasheed, S. et al. Deniable identity-based matchmaking encryption for anonymous messaging. Retrieved from <https://www.semanticscholar.org/paper/91010459a73a5cbeefea77c667581d27bc758c49>

[15] Bawake, H. et al. (2023). A secure messaging application with unbreakable end-to-end encryption. *International Journal of Research and Analytical Studies (IJRASET)*. <https://doi.org/10.22214/ijraset.2023.50805>